App Risk Auditor — Scoring Rubric

PS-01 deliverable 02 · generated from rubric.json v1 by tools/render_rubric.py · do not edit by hand

---

Bands

Low 0-29 · Medium 30-59 · High 60-79 · Critical 80-100

Score construction

min(permission categories, 45) + min(special access, 60) + provenance + manifest + threat intel + combinations + context mismatch
then x system-app dampening, clamped 0-100. Network category capped at 5.

The permission cap is load-bearing: permissions alone can never exceed Medium.

Permission categories (base / cap / diminishing)

Special access	30	60	0.60
Sms	26	30	0.50
Contacts and call logs	16	20	0.50
Camera and microphone	18	22	0.50
Location	14	18	0.50
Phone and identity	11	14	0.50
Storage and media	12	15	0.50
Background and persistence	7	9	0.40
Network	8	5	0.40
Accounts calendar sensors nearby	9	12	0.50

Special access (enabled / declared only)

Accessibility	30	12
Device admin	28	10
Notification listener	26	10
Overlay	25	9
Install packages	22	8
All files access	22	8
Vpn service	20	7
Usage stats	16	6
Battery optimization exempt	6	2

Multipliers

Protection: Dangerous x1.00 · Special x1.00 · Signature x0.80 · Normal x0.60 · Unknown x0.00
State: granted x1.00 · declared-not-granted x0.30 · not grantable x0.00

Combination rules (predicate ids match CombinationRules.kt)

+25	COMBO_ACCESSIBILITY_OVERLAY	floor critical	This app can both read your screen and draw over it
+22	COMBO_CAMERA_MIC_INTERNET_BOOT_HIDDEN	floor high	It can record you, send it online, restarts itself, and has no icon
+20	COMBO_SMS_INTERNET_BOOT_SIDELOADED	floor high	It can read your texts, send them online, and restarts itself
+20	COMBO_ACCESSIBILITY_INSTALL_PACKAGES	floor high	It can tap buttons for you and install other apps
+20	COMBO_BACKGROUND_LOCATION_BOOT_HIDDEN	floor high	It tracks your location in the background and has no icon
+18	COMBO_NOTIFICATION_LISTENER_INTERNET_SMS	floor high	It can read your notifications and your texts, and send them online
+18	COMBO_INSTALL_PACKAGES_SIDELOADED_INTERNET	floor high	It can download and install more apps, and did not come from a store
+16	COMBO_VPN_INTERNET_SIDELOADED	floor high	All of your internet traffic can be routed through this app
+15	COMBO_DEVICE_ADMIN_NOT_SECURITY	floor high	It has administrator control but is not a security app
+15	COMBO_ACCESSIBILITY_SMS	floor high	It can read your screen and your text messages
+15	COMBO_CONTACTS_CALLLOG_SMS_INTERNET		It can copy your contacts, call history and texts online
+15	COMBO_ALL_FILES_INTERNET_SIDELOADED	floor high	It can read every file on your phone and did not come from a store
+12	COMBO_NOTIFICATION_LISTENER_INTERNET		It can read every notification and send data online
+12	COMBO_OVERLAY_USAGE_STATS		It knows which app you open and can draw over it

Provenance, manifest, intel, context, reducers

Provenance: sideloaded +10 · no install record +8 · unknown installer +6 · Google Play -5 · OEM store -3 · targetSdk<23 +10 · no launcher icon +8 · new install +3
Manifest: debuggable +8 · cleartext +4 · test-only +6 · unguarded provider +6 ea · other exported +2 ea (max 10)
Threat intel: malicious +40 and floor critical · suspicious +15 · hash only, explicit opt-in, default off
Context mismatch: Critical +20 floor critical · High +14 floor high · Medium +8 · Low +4 · only the worst mismatch scores
Reducers: verified MDM device admin x0.20 · verified accessibility tool x0.20 · role holder category x0.25 · system app x0.55 (verified = pinned certificate or trusted store; a name match alone is never trusted)

Every High or Critical app carries at least 3 plain-language reasons, ranked by contribution and emitted by the scoring rules themselves — never written in a separate pass.